DTT-UAB THE HACK · RETO SOC DE TARVIA

Triaje de alertas: tags y score de 1 a 100

Cómo leer las alertas, qué tipos hay, cómo etiquetarlas y puntuarlas, y qué tiene que hacer un programa completo de triaje N1.

7 de noviembre de 2026 · Datos: `03_alertas/alertas.jsonl` (11.061 alertas del 5/10 al 1/11/2026) · Reglas del juego: `01_contexto/politica_soc.md` · Todas las cifras están comprobadas contra el dataset.

La idea en un minuto

1. El SIEM ha generado **11.061 alertas** en cuatro semanas. Ninguna trae etiquetas ni puntuación: solo la `severity` base de su regla, que es la misma para todas las alertas de esa regla.
2. El programa pone a cada alerta unos **tags** (etiquetas) que responden a cinco preguntas: *qué es*, *a qué afecta*, *qué pasó de verdad*, *si estaba autorizado* y *qué pistas de ataque hay*.
3. Con esos tags calcula un **score de 1 a 100**. La franja (informational, low, medium, high, critical) sale de la matriz oficial de la política; los detalles solo mueven el número dentro de la franja.
4. Después **junta las alertas del mismo ataque en un incidente**, decide el veredicto y propone acciones con las aprobaciones que exige la política.

11.061 alertas en el SIEM → **112** patrones distintos → **188** alertas «raras» que hay que mirar → **83** alertas de ataques reales → **12** incidentes = 12 tickets

1 Cómo leer una alerta

Cada línea de `alertas.jsonl` es una alerta en JSON. Lo importante está en seis campos:

Campo	Qué te dice	Cuidado con
`rule_id`	Qué buscaba la regla. En `catalogo_casos_de_uso.csv` tienes su táctica MITRE, su runbook (RB-01…RB-10) y su lógica exacta.	Comprueba que la alerta cumple de verdad esa lógica: UC-OT-001 salta con ENG-WS01, que su propia lógica excluye.
`severity`	La severidad base de la regla.	**No es la final.** Las 532 alertas UC-EDR-001 son «high» y 531 son Excel abriendo SAP.
`entities`	Sobre qué: users, hosts, ips, domains, urls, files, customers, cloud, ai_session.	Es lo que hay que enriquecer con el inventario, la inteligencia y los logs.
`evidence`	Qué pasó de verdad: `action` o `edr_action` (blocked, quarantined, detected_only, allow), `success_count`, `change_ticket`, `signer`, `post_login_actions` …	Aquí está la verdad, pero también el texto que escribe el atacante: asuntos, cuerpos de correo, prompts, descripciones de servicios.
`related_events`	Los `event_id` de `04_logs` con los que tirar del hilo.	Los logs muestran cosas que nunca generaron alerta.
`created_at`	Cuándo saltó, **en UTC** (la «Z» final).	El calendario de cambios, RRHH y el horario laboral van en hora de Madrid: UTC+2 hasta el 25/10 y UTC+1 después.

Orden de lectura (el mismo para cualquier alerta):

① qué buscaba la regla → ② sobre qué entidades → ③ qué pasó de verdad → ④ ¿estaba autorizado? (comprobado) → ⑤ qué más pasa alrededor (±24 h) → ⑥ veredicto, severidad y acción

Veredicto	Cuándo se usa
`true_positive` (TP)	Ataque o actividad maliciosa real, aunque un control lo bloqueara.
`benign_true_positive` (BTP)	La regla acertó, pero la actividad estaba autorizada: cambio aprobado, flujo autorizado o viaje notificado.

Veredicto	Cuándo se usa
`false_positive` (FP)	La regla saltó con actividad normal que no debería detectar.
`needs_more_info`	Faltan datos para decidir; se apuntan las dudas en `open_questions`.

2 Tipos de alertas

El catálogo tiene 44 reglas en 11 familias. En el dataset aparecen 41: UC-IDP-007, UC-EDR-009 y UC-EDR-010 no saltan nunca.

Familia	Fuente	Alertas	Casi todo es…	Lo que importa
Web / tienda	WAF, ECOM	3.495	3.386 escaneos de Internet bloqueados, 20 del pentest autorizado y 73 ráfagas de login frenadas por rate limit (0 accesos).	Credential stuffing con accesos buenos y 12 tomas de cuenta con compra de tarjetas regalo.
Endpoint	EDR	2.307	Inventario de SCCM con PowerShell codificado (1.349, cambio aprobado), Excel → saplogon firmado por SAP (531) y antivirus que ya puso el fichero en cuarentena (411).	Loader con persistencia, LSASS, vssadmin, minero, lectura de memoria de los TPV y EDR parado.
Correo	EMAIL_GW	2.301	2.286 reportes de usuarios: newsletters, notificaciones legítimas y el simulacro de phishing de RRHH.	Adjunto .js de un proveedor suplantado, clics de phishing, petición de cambio de IBAN y la campaña de Packaging Iberia (9 reportes).
Red	PROXY, DNS, NGFW	1.425	Beacons a Microsoft, Google, BMC o impresoras (744), dominios de CDN con pinta de DGA (561), consultas de reputación de antivirus (79) y escaneos de NESSUS01 (19, aprobados).	Cobalt Strike, beacon desde los TPV, túnel DNS desde WMS01, escaneo interno y PsExec.
Identidad	IDP, AD, VPN	981	Viaje imposible por la salida de una VPN comercial con el móvil corporativo de siempre (899) y legacy auth bloqueado (61).	AiTM, fatiga MFA, password spraying con un acierto, alta en Domain Admins y un proveedor que entra desde un origen nuevo.
IA (Vela)	AI_GATEWAY	416	Clientes corrigiéndose («olvida la talla que te dije»): 413.	2 prompt injections y 1 intento de leer pedidos de otro cliente con fuga en la respuesta siguiente.
Datos	DLP	62	Fotos de campaña a WeTransfer sin datos personales (58) y nóminas a la gestoría (2, flujo aprobado).	Una empleada que se va y se lleva el CRM.
Cloud	CLOUD	53	Cambios de Terraform en el bucket público de medios (50).	Clave AWS robada, usuario administrador nuevo y descarga de 112 GB.
CI/CD	CICD	11	Paquetes conocidos con script de instalación: puppeteer, sharp, esbuild (10).	Dependency confusion con robo de secretos.
OT	NGFW	10	ENG-WS01, que es un origen permitido (9): fallo de la regla.	1 acceso de mantenimiento por JUMP01 con cambio aprobado.

> **El dato clave.** Si agrupas por regla + evidencia (quitando los campos que cambian en cada alerta, como `message_id`, `reported_by`, `hits` o `entropy`), las 11.061 alertas son solo **112 patrones**. Los 47 patrones que se repiten 20 veces o más suman 10.873 alertas (98 %) y son ruido o actividad autorizada; ahí caen 723 de las 788 alertas high y critical. Quedan **188 alertas raras**: las 83 de los 12 ataques reales, 50 de cambios y flujos aprobados y 55 de ruido poco frecuente.

3 Sistema de tags

Cada tag tiene la forma `familia:valor` y guarda el `event_id` que lo justifica. Así el `evidence` y el `severity_rationale` del ticket salen casi solos, y cualquiera puede comprobar por qué una alerta tiene ese score.

Familia	Ejemplos	De dónde sale	Efecto en el score
`tipo:` `mitre:` `fase:`	`tipo:identidad`, `mitre:T1003.001`, `fase:credenciales`	Catálogo de casos de uso	Ninguno directo: agrupan y cuentan las fases de una cadena.
`activo:`	`critico`, `pci`, `ot`, `internet`, `sin-edr`, `no-cmdb`	`activos.csv`, `servicios_negocio.csv`, `zonas_red.csv`	Eligen la columna de la matriz (criticidad).
`id:`	`vip`, `privilegiada`, `servicio`, `externo`, `sin-mfa`, `huerfana`	`usuarios.csv`	`vip` o `privilegiada`: +1 nivel.
`rrhh:`	`baja-voluntaria`, `viaje`, `vacaciones`, `alta-nueva`	`eventos_rrhh.csv`	`baja-voluntaria`: +3. Un viaje puede justificar la alerta.
`efecto:`	`bloqueado`, `solo-detectado`, `ejecutado`, `acceso-ok`, `persistencia`, `credenciales`, `datos-fuera`, `dinero`, `fuga-ia`, `actividad-posterior`	`evidence` + logs	**El más importante.** Efecto confirmado: +1 nivel. Bloqueado y sin nada después: −1.
`objetivo:`	`inexistente` (ruta o recurso que no existe)	WAF, logs web	Con `efecto:bloqueado`: informational.
`negocio:`	`datos-personales`, `pagos`, `venta-online`, `logistica`	Servicios de negocio + coincidencias del DLP	Datos personales o pagos: +1 nivel. Decide a quién se avisa.
`intel:`	`ioc-ti`, `tor`, `hosting`, `vpn-comercial`, `dominio-nuevo`, `asn-nuevo`, `lookalike`, `sin-firma`, `ua-anomalo`, `spf-dmarc-fail`, `texto-oculto`	`ti_feed.jsonl`, `geoip_asn.csv`, `sandbox_informes.jsonl`, cabeceras	+3 cada uno.
`horario:`	`noche-finde`, `fuera-ventana-contrato`	`created_at` **pasado a hora local**	+3 cada uno.
`viola:`	`adm-fuera-de-jump01`, `rmm-no-aprobado`, `ot-origen-no-autorizado`	Reglas internas de `empresa_tarvia.md`	+3.
`engaño:`	`ticket-falso`, `suplanta-proveedor`, `dependency-confusion`	Algo se presenta como autorizado u oficial y no lo es	+6.
`pista:`	`dispositivo-conocido`, `firmado-fabricante`, `asn-habitual`	`evidence`, inventario	−3 (pistas de que es legítimo).
`benigno:`	`cambio:CHG-2026-1042`, `flujo:FLUJO-0007`, `viaje-notificado`	`calendario_cambios.csv`, `eventos_rrhh.csv`, comprobado	Veredicto BTP: informational, o low si había algo que subía.
`ruido:`	`sap-excel`, `egreso-vpn`, `cdn-entropia`, `av-dnsbl`, `telemetria`, `newsletter`, `lenguaje-natural`, `paquete-conocido`, `sin-datos-personales`	Patrones repetidos y sin riesgo	Veredicto FP: informational y propuesta para afinar la regla.
`cadena:` `notificar:`	`cadena:INC-03`, `notificar:dpo-72h`, `pci`, `tesoreria`, `fraude`, `operaciones-ot`, `equipo-ia`	Correlación	Bonus del incidente y lista de a quién avisar.

Benigno o ruido. `benigno:` quiere decir «la regla acertó, pero estaba autorizado», y necesita una prueba en el calendario de cambios o en RRHH. `ruido:` quiere decir «la regla ha saltado con algo normal que no debería detectar», y va siempre con una propuesta para afinar la regla.

Regla de oro. Un tag `benigno:` solo se pone si el cambio o el evento existe **y** cuadran el alcance, la ventana horaria (en hora local) y el origen. Que la alerta diga «autorizado» no vale. El servicio malicioso de los TPV se describe como «Instalado por Seguridad (ticket SEC-2210)», y ese ticket no existe en el calendario. Eso es `engaño:ticket-falso` (+6), no un benigno.

4 Score de 1 a 100

informational	low	medium	high	critical
1–19	20–39	40–59	60–79	80–100

Score	Severidad	Tiempo de triaje	Escalado y aviso	Qué se hace
1–19	informational	Revisión en lote diaria	No	Cerrar; si es ruido, proponer exclusión.
20–39	low	24 h	No	Cerrar con nota o vigilar.
40–59	medium	4 h	Al N2 si tras el triaje hay indicios de compromiso	Investigar.
60–79	high	30 min	N2 en la misma jornada; aviso al responsable del SOC	Contener lo que puede el N1 y proponer el resto.
80–100	critical	15 min	N2 de guardia por teléfono; responsable del SOC y CISO	Contener ya y escalar.

Cómo se calcula

1. **Nivel base = la matriz oficial** (apartado 2 de `politica_soc.md`): severidad de la regla × criticidad de la entidad **más crítica** afectada, sea el host, el servicio de negocio que toca o el puesto del usuario.
2. **Ajuste oficial, como mucho un nivel.** +1 si hay un efecto confirmado (ejecutado, acceso-ok, persistencia, credenciales, datos-fuera, dinero), una identidad VIP o privilegiada, o datos personales o pagos. −1 si un control lo bloqueó y no hubo nada después. Aunque haya varios motivos, sube o baja un nivel como máximo.
3. **Veredicto.** Con `benigno:` es BTP y se queda en informational (o low si había algo que subía). Con `ruido:` es FP e informational. Bloqueado contra un objetivo que no existe: informational, como en `ticket_ejemplo.json`.
4. **Score = 10 + 20 × nivel + afinado.** Los niveles van de 0 (informational) a 4 (critical). El afinado suma los pesos de los tags (`intel`, `viola`, `horario` y `rrhh:baja-voluntaria` +3; `engaño` +6; `pista` −3) y se recorta a ±9, así que nunca cambia la franja: solo ordena la cola dentro de ella.
5. **Score del incidente** = el máximo de sus alertas + 3 por cada fase extra de la cadena, con tope 100. Suelos: 90 si hay vssadmin, TPV, IBAN, o robo de credenciales seguido de movimiento lateral; 60 si la cadena tiene tres fases o más aunque cada alerta por separado sea low (apartado 5 de la política).

Matriz oficial (severidad de la regla × criticidad del activo)

Regla \ Activo	Baja	Media	Alta	Crítica
informational	info	info	low	low
low	info	low	low	medium
medium	low	medium	medium	high
high	medium	high	high	critical
critical	high	critical	critical	critical

> **La confianza va aparte.** El score dice cuánto importa; la confianza (de 0 a 1), cuánto estás seguro. Pon 0,9 o más si lo confirman dos fuentes independientes (EDR + cortafuegos, TI + sandbox) y entre 0,6 y 0,8 si solo hay una. Por debajo de 0,6, `needs_more_info` con sus `open_questions`.

```
# La función entera: matriz + ajuste ±1 + veredicto + afinado
NIV = ["informational", "low", "medium", "high", "critical"]
CRIT = {"Baja": 0, "Media": 1, "Alta": 2, "Crítica": 3}
MATRIZ = [[0,0,1,1], [0,1,1,2], [1,2,2,3], [2,3,3,4], [3,4,4,4]]
SUBE = {"efecto:ejecutado", "efecto:acceso-ok", "efecto:persistencia",
        "efecto:credenciales", "efecto:datos-fuera", "efecto:dinero",
        "id:vip", "id:privilegiada",
        "negocio:datos-personales", "negocio:pagos"}
PESO = {"intel": 3, "viola": 3, "horario": 3,
        "rrhh:baja-voluntaria": 3, "engaño": 6, "pista": -3}

def puntuar(sev_regla, criticidad, tags):
    n = MATRIZ[NIV.index(sev_regla)][CRIT[criticidad]]
    sube = bool(tags & SUBE)
    baja = ("efecto:bloqueado" in tags
            and "efecto:actividad-posterior" not in tags)
    n = max(0, min(4, n + sube - baja))     # ±1 nivel como máximo
    veredicto = "true_positive"
    if any(t.startswith("benigno:") for t in tags):
        veredicto, n = "benign_true_positive", min(n, 1 if sube else 0)
    elif any(t.startswith("ruido:") for t in tags):
        veredicto, n = "false_positive", 0
    elif {"efecto:bloqueado", "objetivo:inexistente"} <= tags:
        n = 0                               # como ticket_ejemplo.json
    afinado = sum(PESO.get(t, PESO.get(t.split(":")[0], 0)) for t in tags)
    return 10 + 20 * n + max(-9, min(9, afinado)), NIV[n], veredicto
```

Ejemplo completo: de la alerta al score

```
// ALR-20261010-011797 (simplificada)
{
  "alert_id": "ALR-20261010-011797",
  "created_at": "2026-10-10T00:42Z",
  "rule_id": "UC-NET-004",
  "severity": "high",
  "entities": {
    "hosts": ["WS-BCN-1770", "FS01"],
    "users": ["adm.aortega"]
  },
  "evidence": {
    "src": "WS-BCN-1770",
    "dst": "FS01",
    "method": "PsExec (servicio PSEXESVC)",
    "account": "adm.aortega",
    "change_ticket": "ninguno"
  }
}
```

1. Regla UC-NET-004 (movimiento lateral con SMB, RDP o PsExec), severidad base **high**.
2. Hora: 00:42 UTC son las **02:42 del sábado** en Madrid → `horario:noche-finde` (+3).
3. Entidades: WS-BCN-1770 es «Media» y FS01 es «Alta» (unidades compartidas de Finanzas, Compras y Personas) → criticidad **Alta**.
4. adm.aortega es una cuenta privilegiada → `id:privilegiada`. Se usa desde WS-BCN-1770 y no desde JUMP01 → `viola:adm-fuera-de-jump01` (+3). No hay ningún cambio en el calendario.
5. PsExec instaló su servicio en FS01 → `efecto:acceso-ok`.
6. Matriz: high × Alta = **high** (nivel 3). Ajuste +1 → **critical** (nivel 4).
7. Score = 10 + 20 × 4 + (3 + 3) = **96 critical**: llamada al N2 de guardia en 15 minutos.
8. Contexto: en ese mismo equipo entró un adjunto .js el día antes, y 19 minutos antes se volcó LSASS con la credencial de adm.aortega en caché → `cadena:INC-01`. El incidente sube a 100.

La misma regla da resultados opuestos

Calculado con la función de arriba y los tags indicados. Es lo que demuestra que la severidad base de la regla no sirve por sí sola.

Regla (base)	Caso	Tags que deciden	Criticidad	Resultado
UC-EDR-001 high	Excel → saplogon firmado por SAP SE (×531)	`ruido:sap-excel` `pista:firmado-fabricante`	Media	7 FP
	wscript → msiexec → rundll32 con clave Run (Marta Puig)	`efecto:ejecutado` `efecto:persistencia`	Media	90 TP

Regla (base)	Caso	Tags que deciden	Criticidad	Resultado
UC-IDP-001 medium	Salida de VPN comercial con el móvil de siempre (×899)	`ruido:egreso-vpn` `intel:vpn-comercial` `pista:dispositivo-conocido`	Media	10 FP
	Ricard Castells (VIP) en Nueva York, viaje notificado a RRHH	`benigno:viaje-notificado` `id:vip` `pista:dispositivo-conocido`	Alta	27 BTP
	Sergio Navarro: tras el login descarga nóminas y registra un MFA nuevo	`efecto:acceso-ok` `efecto:persistencia` `negocio:datos-personales` `intel:vpn-comercial` `horario:noche-finde`	Media	76 TP → incidente 100
UC-DLP-001 high	Fotos de campaña a WeTransfer, 0 datos personales (×58)	`ruido:sin-datos-personales`	Media	10 FP
	Núria Vidal, que se va a la competencia: 216 MB cifrados a mega.nz tras sacar 380.112 filas del CRM	`efecto:datos-fuera` `negocio:datos-personales` `rrhh:baja-voluntaria`	Crítica (CRM)	93 TP
UC-IDP-008 high	adm.aferrer entra en Backup Operators desde JUMP01 con CHG-2026-1078	`benigno:cambio:CHG-2026-1078` `id:privilegiada`	Crítica (AD)	30 BTP
	adm.aortega mete en Domain Admins a svc_print_upd (creada un minuto antes) desde PRINT01 de madrugada	`id:privilegiada` `efecto:persistencia` `viola:adm-fuera-de-jump01` `horario:noche-finde`	Crítica (AD)	96 TP
UC-EDR-011 critical	6 servidores el 24/10 entre las 20:06 y las 20:51, dentro de CHG-2026-1080	`benigno:cambio:CHG-2026-1080`	Crítica	10 BTP
	PRINT01: el agente lo para spoolhlp.exe, sin firma	`efecto:ejecutado` `intel:sin-firma` `horario:noche-finde`	Baja	96 TP
UC-DEV-001 medium	puppeteer, sharp y esbuild (×10): solo leen PATH y HOME	`ruido:paquete-conocido`	Alta	10 FP
	tarvia-checkout-utils del registro público lee AWS_* y NPM_TOKEN, los envía fuera y se despliega	`efecto:ejecutado` `efecto:credenciales` `engaño:dependency-confusion` `intel:dominio-nuevo`	Alta	79 TP → incidente 100
UC-VPN-001 low	Logisoft desde su ASN de siempre con CHG-2026-1071 (16/10, 22:15)	`benigno:cambio:CHG-2026-1071` `efecto:acceso-ok` `pista:asn-habitual`	Alta (WMS01)	27 BTP
	Logisoft desde Limited Network LTD, de madrugada (×6)	`efecto:acceso-ok` `intel:asn-nuevo` `horario:noche-finde` `horario:fuera-ventana-contrato`	Alta (WMS01)	59 TP → incidente ≈ 80
UC-WEB-001 low	Escáner de Internet bloqueado contra rutas que no existen	`efecto:bloqueado` `objetivo:inexistente` `intel:hosting`	Crítica (tienda)	13 TP
	Pentest desde 192.0.2.10-12 (×20)	`benigno:cambio:CHG-2026-1042` `efecto:bloqueado`	Crítica (tienda)	10 BTP
UC-EDR-002 medium	PowerShell codificado lanzado por CcmExec.exe (SCCM) en su ventana de 08 a 10 h (×1.349)	`benigno:cambio:CHG-2026-1031` `pista:firmado-fabricante`	Media	7 BTP

5 Lo que un buen programa debería encontrar

Las 83 alertas de ataques reales forman 12 incidentes. Los números de la columna «Alertas» son el final del `alert_id` (011790 = ALR-2026…-011790). Sirven como lista de validación del programa.

#	Incidente	Alertas	Score	Avisar a
1	Adjunto .js de un proveedor suplantado (Marta Puig, Compras) → loader con persistencia → Cobalt Strike → reconocimiento con AdFind → volcado de LSASS con la credencial de adm.aortega → PsExec a FS01 → vssadmin bloqueado. El 18/10, con la misma cuenta, alta de svc_print_upd en Domain Admins y EDR parado en PRINT01.	011790–011798, 011895–011896 (11)	100	N2 de guardia, CISO (patrón de ransomware)
2	Dependency confusion en CI-RUNNER01 → la clave AWS de despliegue se usa desde Kali → usuario backup-sync con AdministratorAccess → 1.400 GetObject (≈ 112 GB) de copias del CRM.	011901, 011819–011821 (4)	100	DPO: AEPD y CNPD en 72 h
3	AiTM contra Laura Ferrer → token reutilizado con python-requests → regla de buzón que esconde «factura», «IBAN» y «pago» → correo pidiendo cambiar el IBAN a una cuenta de Lituania por 148.320 €, enviado desde la misma IP del login.	011785–011789 (5)	100	Tesorería, N2
4	AnyDesk no aprobado en LT-T07-02 (sesión entrante desde Marruecos que recorre \\FS01\Tiendas) → possvc.exe sin firma lee la memoria de TarviaPOS en 3 TPV con un «ticket SEC-2210» falso → beacon de los 3 TPV a pos-update-service.example.	011829, 011897–011900 (5)	100	PCI (adquirente), N2 y negocio
5	Credential stuffing contra la API de la app (3.200 fallos en 15 min, 48 IPs, sin captcha) con 6–8 accesos buenos por oleada → 12 tomas de cuenta: cambio de email y compra de tarjetas regalo con la tarjeta guardada.	011799–011814 (16)	100	Fraude, e-commerce
6	Fatiga MFA a Sergio Navarro: 27 notificaciones en 9 minutos, aprobada el sábado a las 23:41 → descarga de nóminas y registro de un MFA nuevo.	011827–011828 (2)	100	N2, DPO
7	Password spraying contra 161 cuentas de la VPN («Otono2026!») → acierta con svc_backup, que entra desde Tor y sin MFA → RDP a BACKUP01 y reconocimiento. Esto último solo está en los logs: no generó alerta.	011815–011816 (2)	≥ 90	N2; apuntar el detection gap
8	Campaña que suplanta a Packaging Iberia: 9 reportes, 3 clics y la sesión robada de Lucía Castro (Tesorería), reutilizada con axios.	011902–011914 (13)	≥ 90	Tesorería, N2
9	Núria Vidal (último día el 16/10, se va a un competidor) saca 380.112 filas del CRM, sube 216 MB cifrados a mega.nz y se manda a su correo personal 41.200 emails y 39.800 teléfonos.	011817–011818 (2)	96	DPO, RRHH, legal
10	Jenkins expuesto a Internet (CVE-2024-23897 sin parchear) → minero XMR que se hace llamar «kswapd0», con crontab cada 5 minutos y conexión al pool 141.94.96.144:3333.	011825–011826 (2)	≥ 90	N2
11	ext.logisoft entra de madrugada desde un ASN nuevo (Limited Network LTD) → WMS01 hace consultas DNS TXT largas a cdn-wms-metrics.example, un dominio de 15 días, cada noche entre las 03 y las 04 durante casi tres semanas. Es un túnel DNS en uno de los dos equipos que pueden hablar con la red OT.	011877–011894 (18)	≈ 80	N2, Operaciones (sin tocar OT)
12	Prompt injection contra Vela desde una misma IP con dos cuentas de cliente: la herramienta deniega el pedido de otro cliente, pero el asistente revela códigos internos en el mensaje siguiente.	011822–011824 (3)	≥ 80	Equipo de IA

Benignos que se cierran en lote (BTP)

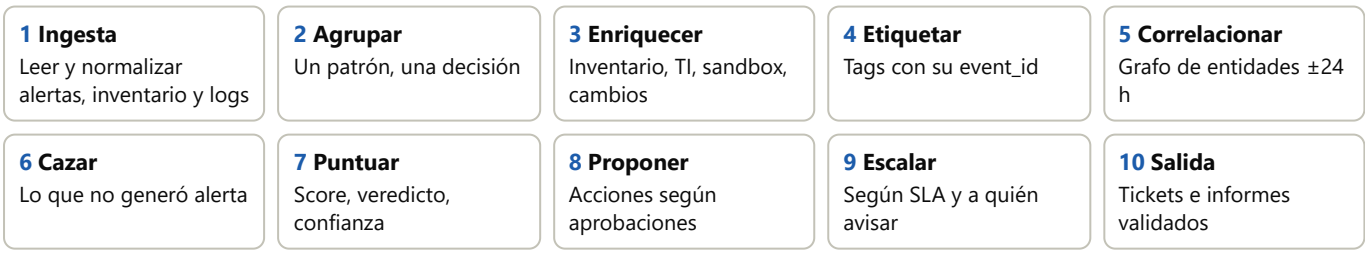
Qué	Autorización	Alertas
Pentest de la tienda online desde 192.0.2.10-12	CHG-2026-1042 (8–10/10)	20 WEB-001 (011830–011849)

Qué	Autorización	Alertas
Escaneos de NESSUS01 los miércoles de 01 a 05 h	CHG-2026-1049 a 1052	19 NET-003 (011850–011868)
Despliegue con PsExec desde JUMP01 (adm.dnavarro)	CHG-2026-1057 (13/10, 10–13 h)	4 NET-004 (011869–011872)
Ricard Castells en Nueva York	Viaje en RRHH (11–14/10)	1 IDP-001 (011873)
Nóminas a la gestoría (marc.reyes)	FLUJO-0007	2 DLP-002 (011874–011875)
Mantenimiento OT por JUMP01, 17/10 a las 09:12	CHG-2026-1063 (08–14 h)	1 OT-001 (011876)
adm.aferrer en Backup Operators	CHG-2026-1078 (23/10)	1 IDP-008 (011915)
Paradas del EDR en 6 servidores	CHG-2026-1080 (24/10, 20–22 h)	6 EDR-011 (011916–011921)
Actualización del WMS por Logisoft	CHG-2026-1071 (16/10, 21–24 h)	1 VPN-001 (011922)
Inventario de software por SCCM	CHG-2026-1031 (diario, 08–10 h)	1.349 EDR-002

Reglas que conviene afinar (propuestas de tuning)

Regla	Propuesta	Alertas que quita
UC-OT-001	Excluir ENG-WS01 y WMS01, como dice su propia lógica.	9
UC-EDR-001	Excluir EXCEL.EXE → saplogon.exe firmado por SAP SE.	531
UC-EDR-002	Excluir CcmExec.exe dentro de la ventana de CHG-2026-1031 (o cerrarlas solas como BTP).	1.349
UC-IDP-001	No saltar por la salida de una VPN comercial con dispositivo conocido y conforme.	899
UC-NET-001	Lista blanca de telemetría de Microsoft, Google, BMC e impresoras.	744
UC-NET-005	Lista blanca de dominios de CDN.	561
UC-NET-006	Excluir consultas A de reputación de antivirus (avqs.mcafee.com, sophosxl.net).	79
UC-DEV-001	Alertar solo si se leen secretos o hay un dominio nuevo, como dice su lógica.	10
UC-DLP-001	No alertar solo por tamaño cuando no hay datos personales.	58
UC-AI-001	No marcar las correcciones del cliente en lenguaje natural.	413

6 Qué hace un programa completo



1. **Ingesta y normalización.** Cada hora en UTC y en hora de Madrid (el cambio de hora es el 25/10). Unificar identidades (`TARVIA\svc_backup` = `svc_backup` = su UPN). Sacar la zona de cada IP por CIDR con `zonas_red.csv`. Expandir rangos como `WEB-ECOM01..04`, `POS-T*` o `PLC-SORT01..06`.
2. **Agrupar por patrón.** Firma = regla + evidencia sin los campos variables. Decidir una vez por patrón cierra miles de alertas de golpe y deja tiempo para las 188 raras.
3. **Enriquecer** con la API simulada (`/assets`, `/users`, `/changes`, `/intel`, `/sandbox`, `/logs`) o leyendo los ficheros directamente.
4. **Etiquetar** con reglas deterministas por fuente. Cada tag guarda el `event_id` que lo justifica.
5. **Correlacionar** con un grafo de entidades (usuario, host, IP, dominio, hash, sesión, access key, message_id, cliente) en ±24 h, más los saltos que no comparten nombre: una credencial cacheada en un equipo que luego se usa en otro, un secreto leído en un build que reaparece en CloudTrail, la IP del login AiTM que envía el correo del IBAN o los equipos de

una misma tienda, que comparten red plana. Para la persistencia hace falta una ventana más larga: adm.aortega vuelve ocho días después.

6. **Cazar lo que no alertó.** Buscar en `04_logs` la actividad posterior a cada acceso. El RDP de svc_backup a BACKUP01 y su reconocimiento no tienen alerta: van a `detection_gaps`.
7. **Puntuar y decidir:** score, veredicto, confianza y un `severity_rationale` escrito a partir de los tags.
8. **Proponer acciones.** El N1 solo ejecuta `block_ioc` y `purge_email`. El resto va con `requires_approval: true` y un token de `POST /approvals` que da una persona, nunca el propio programa. La red OT no se toca nunca. mega.nz y AnyDesk no se bloquean para toda la empresa sin el N2. Antes de deshabilitar una cuenta de servicio (svc_backup, svc_ecom_deploy) hay que avisar de qué deja de funcionar.
9. **Escalar y notificar** según la franja. Muchos de estos ataques dan sus pasos clave de noche o en fin de semana, cuando solo hay una guardia N2 por teléfono. Avisar a quien toque: DPO (72 h), adquirente PCI, Tesorería, Fraude, Operaciones o el equipo de IA.
10. **Salida validada contra los schemas:** un ticket por incidente con todos sus `alert_ids` (`ticket_salida.schema.json`), el informe de fase 2 con paciente cero, cronología, causa raíz, contención y gaps (`informe_incidente.schema.json`) y las propuestas de tuning.

7 Trampas del dataset

> **La hora.** Si comparas en UTC, las 6 paradas del EDR del 24/10 (18:06–18:51 UTC, es decir, 20:06–20:51 en Madrid) quedan fuera de CHG-2026-1080 y te salen 6 críticos falsos. 1.146 de las 1.349 alertas de SCCM parecen fuera de su ventana de 08 a 10 h; en hora local solo quedan 18, entre las 10:00 y las 10:02, así que deja unos minutos de margen. Y el mantenimiento OT de las 07:12 UTC (09:12 en Madrid) parece fuera de su ventana de 08 a 14 h.

- **La hora escrita dentro de la evidencia puede estar mal.** La alerta de Domain Admins dice «sábado 03:13», pero el 18/10/2026 es domingo y `created_at` da las 03:16. Calcula siempre la hora local a partir de `created_at`.
- **La criticidad es la de lo más crítico que se toca.** PRINT01 es «Baja», pero meter a alguien en Domain Admins toca el directorio activo, que es «Crítica».
- **«Bloqueado» no siempre resta.** El vssadmin bloqueado en FS01 llega después de un volcado de LSASS y un PsExec, y la cadena sigue días después. Hay actividad posterior, así que no se aplica el −1.
- **A veces la regla está mal.** UC-OT-001 salta con ENG-WS01, que su propia lógica excluye. Es un FP y además hay que proponer el arreglo.
- **No todo lo de un proveedor es el ataque.** De las 10 alertas de Logisoft, 6 son el ataque (Limited Network LTD), 1 es el cambio CHG-2026-1071 y 3 son conexiones desde su origen habitual unos minutos después de las 18 h: low, y conviene recordárselo al proveedor.
- **El texto lo escribe el atacante:** asuntos y cuerpos de correo, prompts de Vela, descripciones de servicios y user agents. Algunos correos llevan texto oculto en HTML dirigido a los clasificadores automáticos (`intel:texto-oculto`). Si usáis un LLM, el veredicto tiene que salir de los tags y la evidencia, nunca de lo que diga ese texto.

8 Glosario

AiTM. «Adversary in the middle»: una web de phishing que hace de intermediaria con el login real y roba la cookie de sesión aunque haya MFA.

ATO. «Account takeover»: el atacante se queda con la cuenta de un cliente.

BEC. «Business email compromise»: fraude desde un buzón legítimo comprometido; el típico es pedir un cambio de IBAN.

Beacon. Conexión periódica de un malware a su servidor de control (C2).

Credential stuffing. Probar en masa pares de usuario y contraseña filtrados en otras webs.

Password spraying. Probar una contraseña muy común contra muchas cuentas a la vez.

DGA. Dominios generados por algoritmo. Los nombres de los CDN se parecen y engañan a la regla.

Dependency confusion. Publicar en el registro público un paquete con el nombre de uno interno para que el build lo instale.

Detection gap. Actividad maliciosa que no generó ninguna alerta.

LSASS. Proceso de Windows que guarda credenciales en memoria. Volcarlo es robar credenciales.

PsExec. Herramienta de administración remota que los atacantes también usan para moverse entre equipos.

vssadmin. Borrar las instantáneas de volumen: el paso típico antes de cifrar con ransomware.

Túnel DNS. Sacar datos o recibir órdenes escondiéndolos dentro de consultas DNS.

MITRE ATT&CK. Catálogo de tácticas y técnicas de ataque (T1078, T1003.001…).

IOC. Indicador de compromiso: IP, dominio, hash…

N1 / N2. Primer y segundo nivel del SOC. El N1 tría; el N2 investiga y aprueba la contención.

SLA. Tiempo máximo para triar una alerta según su severidad.

PCI DSS. Norma de seguridad para los datos de tarjetas: TPV y pasarela de pago.

DPO. Delegado de protección de datos. Notifica las brechas a la AEPD (y a la CNPD portuguesa) en 72 h.

UTC / CEST / CET. Hora universal. Madrid va a UTC+2 (CEST) hasta el 25/10/2026 y a UTC+1 (CET) después.